

TSEC Risk & Cyber Advisory LLC

Integrated Cybersecurity, Risk & Compliance Advisory

Document 04

NIST CSF Implementation Guide

NIST Cybersecurity Framework 2.0 — Implementation for Regulated Organizations

[NIST CSF 2.0](#) | [NIST SP 800-53](#) | [NIST SP 800-171](#)

Document ID:	NIST-01
Framework Layer:	LAYER 1: CYBERSECURITY FRAMEWORK
Version:	1.0
Effective Date:	June 1, 2026
Classification:	CONFIDENTIAL
Prepared by:	TSEC Risk & Cyber Advisory LLC

1. Purpose

This guide provides TSEC Risk & Cyber Advisory LLC's implementation framework for the NIST Cybersecurity Framework (CSF) 2.0 for [Organization Name]. It maps organizational cybersecurity activities to the six CSF Core Functions, establishes implementation tiers, and provides a structured roadmap for improving cybersecurity posture in alignment with business and regulatory requirements.

2. NIST CSF 2.0 Overview

The NIST CSF 2.0 (released February 2024) organizes cybersecurity outcomes across six Core Functions. The addition of the GOVERN function in version 2.0 establishes cybersecurity risk management as an enterprise-level priority:

Function	Acronym	Description
Govern	GV	Establish and monitor cybersecurity risk management strategy, expectations, and policy
Identify	ID	Understand assets, risks, and the organizational cybersecurity context
Protect	PR	Implement safeguards to manage cybersecurity risks
Detect	DE	Identify cybersecurity events and anomalies
Respond	RS	Take action regarding detected cybersecurity incidents
Recover	RC	Restore capabilities impaired by cybersecurity incidents

3. NIST CSF Implementation Tiers

TSEC assesses organizational cybersecurity maturity against four implementation tiers:

Tier	Name	Description
1	Partial	Ad hoc, reactive practices; limited awareness of cybersecurity risk
2	Risk Informed	Practices approved by management; risk-informed but not organization-wide
3	Repeatable	Formally approved policies; organization-wide consistent implementation
4	Adaptive	Continuous improvement; advanced threat intelligence; lessons learned integrated

4. CSF Core Functions — Controls Mapping

4.1 GOVERN (GV)

Establish cybersecurity strategy, risk management, and accountability structures.

Category	Control Outcome	Implementation Activity	Tier Target
GV.OC	Organizational Context — Mission and stakeholder expectations understood	Document business mission, critical services, and regulatory obligations	Tier 3
GV.RM	Risk Management Strategy — priorities, constraints, tolerances established	Board-approved risk appetite; IS steering committee	Tier 3
GV.RR	Roles & Responsibilities — cybersecurity roles and accountability defined	CISO designation; RACI matrix for cybersecurity functions	Tier 3
GV.PO	Policy — IS policies established, communicated, enforced	Policy suite: IS, AUP, access control, incident response	Tier 3
GV.SC	Supply Chain Risk — third-party risks addressed	TPRM program; vendor security requirements in contracts	Tier 2

4.2 IDENTIFY (ID)

Category	Control Outcome	Implementation Activity	Tier Target
ID.AM	Asset Management — inventory of hardware, software, data assets	CMDB/asset inventory; data classification	Tier 3
ID.RA	Risk Assessment — threats and vulnerabilities identified	Annual risk assessment; threat modeling	Tier 3
ID.IM	Improvement — lessons learned incorporated	Post-incident reviews; continuous improvement tracking	Tier 2

4.3 PROTECT (PR)

Category	Control Outcome	Implementation Activity	Tier Target
PR.AA	Identity Mgmt & Access Control — authenticated access based on least privilege	MFA; RBAC; quarterly access reviews	Tier 3

Category	Control Outcome	Implementation Activity	Tier Target
PR.AT	Awareness & Training — security training for all personnel	Annual security awareness; role-based training	Tier 3
PR.DS	Data Security — data at rest and in transit protected	AES-256 encryption; TLS 1.2+; DLP controls	Tier 3
PR.IR	Technology Infrastructure Resilience — resilient infrastructure	Redundancy; backup and recovery procedures; BCP	Tier 2

4.4 DETECT (DE)

Category	Control Outcome	Implementation Activity	Tier Target
DE.CM	Continuous Monitoring — assets and networks monitored for anomalies	SIEM; IDS/IPS; cloud monitoring; endpoint detection	Tier 3
DE.AE	Adverse Event Analysis — anomalies analyzed for potential incidents	Alert triage procedures; correlation rules; threat intel feeds	Tier 2

4.5 RESPOND (RS) & RECOVER (RC)

Category	Control Outcome	Implementation Activity	Tier Target
RS.MA	Incident Management — incidents contained and eradicated	IRP with defined roles; tabletop exercises annually	Tier 3
RS.CO	Incident Response Reporting	72-hr regulatory notification (NYDFS); customer notification	Tier 3
RC.RP	Incident Recovery — restoration plans executed	DR plan; RTO/RPO defined; annual DR test	Tier 2
RC.CO	Recovery Communication	Stakeholder communication plan for major incidents	Tier 2

5. NIST CSF Current State Assessment

TSEC conducts a baseline assessment mapping your current practices against each CSF Function and Category. Results are presented in a maturity dashboard with tier ratings and prioritized improvement roadmap.

CSF Function	Current Tier	Target Tier	Priority Actions
GOVERN	Tier 1	Tier 3	Formalize risk management strategy; establish IS steering committee
IDENTIFY	Tier 2	Tier 3	Complete asset inventory; formalize annual risk assessment
PROTECT	Tier 2	Tier 3	Deploy MFA; implement DLP; complete security training program
DETECT	Tier 1	Tier 2	Implement SIEM; establish monitoring baseline and alert procedures
RESPOND	Tier 2	Tier 3	Finalize IRP; conduct tabletop exercise; test notification procedures
RECOVER	Tier 1	Tier 2	Document DR plan; test backup restoration; define RTO/RPO

6. TSEC Implementation Support

Service	Description
CSF Baseline Assessment	Structured assessment mapping current practices to all CSF 2.0 Functions
Gap Analysis & Roadmap	Prioritized remediation plan with effort estimates and milestones
Policy Development	CSF-aligned security policies and procedures for all Functions
Control Implementation	Hands-on support deploying technical and administrative controls
Maturity Reporting	Quarterly CSF maturity dashboards and executive reporting
Regulatory Alignment	Mapping CSF implementation to NYDFS Part 500, SOC 2, and ISO 27001

7. Contact & Engagement

Organization:	TSEC Risk & Cyber Advisory LLC
Email:	Info@tsecgrc.com

Website:	www.tsecgrc.com
Classification:	CONFIDENTIAL — For Client Use Only